

# OpenBankX - Open Banking / PSD2 API Gateway & Consent Management System

## 1. Introduction

OpenBankX is a web-based **Open Banking / PSD2** platform that enables banks to securely expose account, payment initiation, and confirmation of funds APIs to **TPPs (AISPs/PISPs/CBPIIs)** with strong customer authentication (SCA), consent/grant management, throttling, monitoring, and regulatory reporting.

It supports **developer onboarding, application registration, dynamic client registration (ref), consent capture and lifecycle, OAuth2/OIDC with PKCE, SCA step-up (OTP/device/app-based), API gateway routing, rate limits, fraud/risk hooks (ref), audit and reporting.**

The backend uses a **REST API-based microservice architecture** with **Angular/React** for the developer & bank admin portals, compatible with **Java (Spring Boot)** or **.NET (ASP.NET Core)**.

### Actors / Users

- **TPP Developer:** Registers apps, obtains credentials, tests sandbox, consumes APIs.
- **Bank Customer:** Grants and manages consent; performs SCA when needed.
- **Bank Operations/Compliance:** Monitors API usage, consent lifecycle, and incidents.
- **Open Banking Admin:** Configures API products, policies, limits, SCA factors, and reports.

## 2. Module Overview

### 2.1 Identity, OAuth2/OIDC & SCA

Customer/TPP identity, OAuth2/OIDC flows, SCA policies and step-up.

### 2.2 TPP Onboarding & App Registration

TPP profile, app registration, credentials, redirect URIs, scopes.

### 2.3 Consent & Grant Management

Consent capture, fine-grained scopes, duration, revocation.

### 2.4 API Products, Plans & Throttling

API bundles, quotas, rate-limits, SLAs, sandbox vs production.

### 2.5 API Gateway, Routing & Traffic Control

Secure routing to resource servers, headers/signatures, request/response validation.

### 2.6 Accounts, Payments & Funds APIs (Reference)

Endpoints for AISP, PISP, and CBPII (internal references to core).

## 2.7 Monitoring, Analytics & Incident Management

Usage dashboards, latency, error codes, SLA breaches, incident tickets.

## 2.8 Audit, Compliance & Reporting

Immutable audit, consent history, TPP logs, regulator reports.

## 2.9 Notifications & Alerts

Alerts for consent expiry, abnormal traffic, SLA breaches, key rotation.

# 3. Architecture Overview

- **Frontend:** Angular/React (Developer Portal & Admin Console)
- **Backend:** REST microservices (Auth/Consent/Gateway/Analytics/Reporting)
- **Database:** Relational Database (MySQL/PostgreSQL/SQL Server)
- **Integrations (Phase-1):** Core banking & payment rails **simulated as references**; dynamic client registration and eIDAS/QWAC **referenced only**.

# 4. Module-Wise Design

## 4.1 Identity, OAuth2/OIDC & SCA Module

### Features:

- OAuth2/OIDC (Auth Code + PKCE), Client Credentials for TPP backend, Refresh Tokens
- SCA factors (OTP/Device binding/App approve – reference), step-up policies by scope/transaction
- Token introspection, revocation, JWKs endpoint, rotation policies

### Entities:

- **User**
  - UserID
  - Name
  - Role (Customer/TPP/Operations/Admin)
  - Email
  - Phone
  - Status (Active/Locked)
- **AuthClient**
  - ClientID

- TPPAppID
- ClientType (Confidential/Public)
- RedirectURIs
- ScopesAllowed
- Status (Active/Revoked)
- **Token**
  - TokenID
  - ClientID
  - UserID
  - TokenType (Access/Refresh)
  - Scope
  - IssuedAt
  - ExpiresAt
  - Status (Active/Revoked)
- **SCAEvent**
  - SCAEventID
  - UserID
  - Method (OTP/Device/App)
  - Result (Pass/Fail)
  - EventTime
  - ReferenceID (ConsentID/PaymentID)

## 4.2 TPP Onboarding & App Registration Module

### Features:

- TPP profile, certification references (eIDAS/QWAC – ref), app registration, key upload, redirect URIs validation

### Entities:

- **TPP**
  - TPPID
  - LegalName
  - RegistrationNumber

- ContactInfo
- CertificationRef
- Status (Sandbox/Production/Suspended)
- **TPPApp**
  - TPPAppID
  - TPPID
  - AppName
  - RedirectURIs
  - PublicKeysJWKSet
  - ScopesRequested
  - Status (Pending/Approved/Rejected)

### 4.3 Consent & Grant Management Module

#### Features:

- Consent creation by customer login, scope selection, duration, revocation, fine-grained accounts and permissions

#### Entities:

- **Consent**
  - ConsentID
  - UserID
  - TPPAppID
  - ScopeJSON (accounts:read, balances:read, payments:write, funds:read)
  - ResourceFilterJSON (AccountIDs, date ranges)
  - CreatedDate
  - ExpiryDate
  - Status (Active/Revoked/Expired)
- **ConsentEvent**
  - ConsentEventID
  - ConsentID
  - EventType (Create/Revoke/Expire/Amend)

- EventDate
- PerformedBy (User/TPP/Admin)
- Notes

#### **4.4 API Products, Plans & Throttling Module**

##### **Features:**

- API product catalog, plans (sandbox/prod), quotas, burst limits, SLA policies

##### **Entities:**

- **APIProduct**
  - ProductID
  - Name
  - Description
  - EndpointsJSON
  - Status
- **APIPlan**
  - PlanID
  - ProductID
  - Environment (Sandbox/Production)
  - RateLimitPerMin
  - DailyQuota
  - SLA (ms)
- **TPPSubscription**
  - SubscriptionID
  - TPPAppID
  - PlanID
  - SubscribedDate
  - Status (Active/Suspended/Cancelled)

#### **4.5 API Gateway, Routing & Traffic Control Module**

##### **Features:**

- Validate headers/signatures, JWT validation, scope checks, consent enforcement, rate-limits, request/response validation, routing to resource servers

**Entities:**

- **APILog**
  - APILogID
  - TPPAppID
  - ClientID
  - Endpoint
  - Method
  - StatusCode
  - LatencyMS
  - Timestamp
- **RateLimitCounter**
  - CounterID
  - TPPAppID
  - PeriodStart
  - Count
  - LimitWindow (Minute/Day)

#### **4.6 Accounts, Payments & Funds APIs Module (Reference)**

**Features:**

- Provide AISP (accounts/balances/transactions), PISP (payment initiation), CBPFI (funds confirmation) interfaces (backed by internal references)

**Entities:**

- **AccountRef**
  - AccountID
  - UserID
  - AccountNumberMasked
  - Type (Savings/Current/Card)
  - Currency
  - Status

- **TransactionRef**
  - TxnRefID
  - AccountID
  - TxnDate
  - Amount
  - TxnType (Debit/Credit)
  - Narrative
- **PaymentInitiation**
  - PaymentID
  - TPPAppID
  - DebtorAccountRef
  - CreditorAccountRef
  - Amount
  - Currency
  - Status (Created/Authorized/Rejected/Executed)
  - CreatedDate
- **FundsCheck**
  - FundsCheckID
  - TPPAppID
  - AccountID
  - Amount
  - Currency
  - Result (Sufficient/Insufficient)
  - CheckedDate

## 4.7 Monitoring, Analytics & Incident Management Module

### Features:

- Usage metrics, error codes, latency, SLA breaches; incident recording, RCA tracking

### Entities:

- **APIUsageReport**

- ReportID
- Scope (TPP/Product/Endpoint/Period)
- Metrics (Calls, Errors, LatencyP95, ThrottleEvents)
- GeneratedDate
- **Incident**
  - IncidentID
  - Category (Outage/Latency/Security)
  - Description
  - DetectedDate
  - Status (Open/Mitigated/Closed)

## 4.8 Audit, Compliance & Reporting Module

### Features:

- Immutable audit of auth, consent, API calls; regulator/regtech reports; consent evidence

### Entities:

- **AuditTrail**
  - TrailID
  - ActorType (User/TPP/System)
  - ActorID
  - Action
  - Resource
  - Timestamp
  - Metadata
- **ComplianceReport**
  - CompReportID
  - Scope (TPP/Consent/Period)
  - Metrics (ActiveConsents, Revocations, SCACFailures, Breaches)
  - GeneratedDate

## 4.9 Notifications & Alerts Module



**Features:**

- Consent expiry reminders, key rotation reminders, throttle/incident alerts

**Entities:**

- **Notification**
  - NotificationID
  - RecipientType (User/TPP/Admin)
  - RecipientID
  - Message
  - Category (Consent/Security/Usage/Incident)
  - Status (Unread/Read/Dismissed)
  - CreatedDate

## 5. Deployment Strategy

- **Local:** Angular/React portals + Spring Boot/.NET Core microservices + local DB
- **Production:** Cloud/on-prem, API gateway/WAF, OAuth2/OIDC IdP, secrets vault, HSM/KMS (ref), centralized logging/metrics, autoscaling.

## 6. Database Design

**Tables:**

- User(UserID, Name, Role, Email, Phone, Status)
- AuthClient(ClientID, TPPAppID, ClientType, RedirectURIs, ScopesAllowed, Status)
- Token(TokenID, ClientID, UserID, TokenType, Scope, IssuedAt, ExpiresAt, Status)
- SCAEvent(SCAEventID, UserID, Method, Result, EventTime, ReferenceID)
- TPP(TPPID, LegalName, RegistrationNumber, ContactInfo, CertificationRef, Status)
- TPPApp(TPPAppID, TPPID, AppName, RedirectURIs, PublicKeysJWKSet, ScopesRequested, Status)
- Consent(ConsentID, UserID, TPPAppID, ScopeJSON, ResourceFilterJSON, CreatedDate, ExpiryDate, Status)
- ConsentEvent(ConsentEventID, ConsentID, EventType, EventDate, PerformedBy, Notes)

- APIProduct(ProductID, Name, Description, EndpointsJSON, Status)
- APIPlan(PlanID, ProductID, Environment, RateLimitPerMin, DailyQuota, SLA)
- TPPSubscription(SubscriptionID, TPPAppID, PlanID, SubscribedDate, Status)
- APILog(APILogID, TPPAppID, ClientID, Endpoint, Method, StatusCode, LatencyMS, Timestamp)
- RateLimitCounter(CounterID, TPPAppID, PeriodStart, Count, LimitWindow)
- AccountRef(AccountID, UserID, AccountNumberMasked, Type, Currency, Status)
- TransactionRef(TxnRefID, AccountID, TxnDate, Amount, TxnType, Narrative)
- PaymentInitiation(PaymentID, TPPAppID, DebtorAccountRef, CreditorAccountRef, Amount, Currency, Status, CreatedDate)
- FundsCheck(FundsCheckID, TPPAppID, AccountID, Amount, Currency, Result, CheckedDate)
- APIUsageReport(ReportID, Scope, Metrics, GeneratedDate)
- Incident(IncidentID, Category, Description, DetectedDate, Status)
- AuditTrail(TraillID, ActorType, ActorID, Action, Resource, Timestamp, Metadata)
- ComplianceReport(CompReportID, Scope, Metrics, GeneratedDate)
- Notification(NotificationID, RecipientType, RecipientID, Message, Category, Status, CreatedDate)

## 7. User Interface Design

- **Developer (TPP) Portal:** App registration, keys/JWKs upload, redirect URI config, scopes request, usage analytics, sandbox explorer.
- **Customer Consent UI:** Login, consent review, scope/resource selection, SCA, revoke/renew.
- **Operations Dashboard:** API health, throttle events, latency/error distributions, incidents.
- **Compliance Console:** Consent registry, SCA stats, reports, audit trail search.
- **Admin Console:** API products/plans, rate-limits, SCA policies, user/TPP management.

## 8. Non-Functional Requirements

- **Performance:** Sustain **50,000 concurrent users**; P95 gateway latency < 300ms under nominal load.

- **Security:** OAuth2/OIDC, signed JWTs, TLS everywhere, RBAC, consent enforcement, immutable audit.
- **Scalability:** Horizontal autoscaling of gateway/auth/consent services; multi-region readiness.
- **Availability:** **99.9% uptime**; graceful degradation (rate-limit enforcement over analytics).
- **Maintainability:** Modular services, versioned APIs, policy-driven configs, automated schema migrations.
- **Observability:** Centralized logs, metrics (TPS, latency, errors, throttles), tracing across gateway→resource servers.

## 9. Assumptions & Constraints

- Phase-1 excludes real dynamic client registration and eIDAS/QWAC validation (stored as **references only**).
- Core banking and rail connectors are **simulated**; data served via internal references.
- All notifications are **in-app only** (no email/SMS).
- Fully implementable using **Java Spring Boot/ASP.NET Core + Angular/React** with a relational DB.